الوحدة 11: الأمن السيبراني وإدارة الحوادث

المستوى: **3**

نوع الوحدة: **واجب محدد داخليًا**

ساعات التعلم الموجَّه: **120**

موجزعن الوحدة

يدرس المتعلمون تهديدات الأمن السيبراني والثغرات، والأساليب المستخدمة لحماية الأنظمة من التهديدات وكيفية التخطيط للحوادث الأمنية وإدارتها.

مقدمة الوحدة

إن اعتمادنا المتزايد على أنظمة الكمبيوتر والبيانات التي تحتويها يجعلنا عرضة لهجمات مجرمي الإنترنت وفقدان هذه الأنظمة في حالة وقوع
حادث أو كارثة طبيعية. مع تحسن أمن أنظمة تكنولوجيا المعلومات، يتم تطوير أساليب أكثر تعقيدًا للهجوم، ولذا من الأهمية بمكان أن تضع المؤسسات خططًا قوية للتعامل مع حوادث الأمن السيبراني قبل وقوعها. يتعين على جميع متخصصي تكنولوجيا المعلومات اكتساب فهم جيد للتهديدات الحالية للأنظمة، وكيفية تطبيق أساليب الحماية المناسبة والفعالة وكيفية إدارة حوادث الأمن السيبراني.

تعمل البلدان في جميع أنحاء العالم على تسريع جهودها المبذولة نحو معالجة مخاطر الأمن السيبراني على شبكات الاتصالات الخاصة بالسلامة العامة والمهام الحرجة. في هذه الوحدة، ستدرس العديد من الأنواع المختلفة لهجمات الأمن السيبراني، والثغرات الموجودة في الأنظمة المتصلة بالشبكة والتقنيات التي يمكن استخدامها للدفاع عن أنظمة المؤسسة المتصلة بالشبكة. وستقوم بالتحقيق في التقنيات المستخدمة لتقييم المخاطر وطرق التخطيط للتعامل مع نتائج حادث الأمن السيبراني واستعادة الأنظمة بعد وقوع أي حادث. كما ستجري فحصًا للسيناريوهات وإجراء تقييمات المخاطر وإعداد خطط الحماية قبل حماية الأنظمة المتصلة بالشبكة. ستقوم أيضًا بفحص الأدلة من حوادث الأمن السيبراني والوثائق الأمنية ذات الصلة، وذلك باستخدام الأدلة المقدمة بغرض تقديم توصيات للتحسين.

مع تطور أنظمة تكنولوجيا المعلومات، هناك حاجة متزايدة لمتخصصي تكنولوجيا المعلومات لحماية الأنظمة المتصلة بالشبكة والمعلومات التي تحتوي عليها، مع توفير ميزات وفوائد محسنة للمؤسسات والعملاء والأفراد.

التقييم

تحتوي هذه الوحدة على موجز واجبات محددة من بيرسون. ويجب على المتعلمين إنجاز أي ملخص واجب محدد من قِبل بيرسون.

أهداف التعلم

في هذه الوحدة، ستتمكن من التالي:

(أ) فهم تهديدات الأمن السيبراني وثغرات النظام وأساليب الحماية الأمنية

(ب) استكشاف الآثار الأمنية للأنظمة المتصلة بالشبكة

(ج)وضع خطة حماية الأمن السيبراني لمؤسسة محددة

(د) فحص إجراءات جمع الأدلة الجنائية بعد وقوع الحادث الأمني.

ملخص الوحدة

هدف التعلم	مجالات المحتوى الرئيسية	نهج التقييم
(أ) فهم تهديدات الأمن السيبرانى وثغرات النظام وأساليب الحماية الأمنية	(أ1) تهديدات الأمن السيبراني (أ2) ثغرات النظام (أ3) المسؤوليات القانونية (أ4) تدابير الأمان المادي (أ5) تدابير أمان البرامج والأجهزة	يجري تقييم هذه الوحدة من خلال الواجب المحدد من قِبل بيرسون.
(ب) استكشاف الآثار الأمنية للأنظمة المتصلة بالشبكة	(ب1) أنواع الشبكات (ب2) مكونات الشبكة (ب3) خدمات وموارد البنية التحتية للشبكات	
(ج)وضع خطة حماية الأمن السيبرانى لمؤسسة محددة	(ج1) تقييم الثغرات في أنظمة الكمبيوتر (ج2) تقييم شدة المخاطر في كل تهديد (ج3) خطة الأمن السيبراني للنظام (ج4) السياسات الداخلية (ج5) مزودو الخدمة الخارجية	
(د) فحص إجراءات جمع الأدلة الجنائية بعد وقوع الحادث الأمني	(د1) جمع الأدلة الجنائية (د2) التحليل الجنائي المنهجي لنظام مشبوه	

المحتوى

هدف التعلم (أ): فهم تهديدات الأمن السيبر اني وثغرات النظام وأساليب الحماية الأمنية

(أ1) تهديدات الأمن السيبر اني

تطبيق فهم تهديدات الأمن السيبراني التي تؤثر على المؤسسات في مجموعة من القطاعات والسيناريوهات المهنية.

تعتبر جميع الأنظمة عرضة للهجوم من التهديدات الخارجية والداخلية.

- كيفية حدوث التهديدات الداخلية، بما في ذلك:
  - أعمال التخريب والسرقة من جانب الموظفين، بما في ذلك المعدات المادية أو البيانات، والأضرار مثل الحرائق والفيضانات وفقدان الطاقة أو الكوارث الأخرى
  - الوصول غير المصرح به من قبل الموظفين والمستخدمين الآخرين إلى المناطق الآمنة ووظائف الإدارة، بما في ذلك مستويات الأمان والبروتوكولات
  - تدابير الأمن السيبراني الضعيفة والممارسات غير الآمنة، بما في ذلك أمن أجهزة الكمبيوتر وأجهزة التخزين، والتدقيق الأمني للزوار، وزيارة مواقع الويب غير الجديرة بالثقة
  - فقدان البيانات أو الكشف عنها بشكلٍ عرضي، بما في ذلك ضعف تدريب الموظفين ومراقبتهم.
- كيفية عمل التهديدات الخارجية، بما في ذلك:
  - البرامج الضارة (البرامج الضارة)، بما في ذلك برامج التجسس والبرامج الإعلانية وبرامج الفدية؛ الفيروسات، بما في ذلك الفيروسات المتنقلة والفيروسات الجذرية الخفية وأحصنة طروادة
  - القرصنة، بما في ذلك القرصنة التجارية والحكومية ومن جانب الأفراد
  - التخريب، بما في ذلك أعمال التخريب التجاري والحكومي ومن جانب الأفراد
  - تقنيات الهندسة الاجتماعية المستخدمة للحصول على معلومات آمنة عن طريق الخداع.
- من المرجح أن يؤدي تأثير التهديد الموثوق به إلى وقوع شكل من أشكال الخسارة، مثل:
  - الخسارة التشغيلية، بما في ذلك مخرجات التصنيع وتوافر الخدمة وبيانات الخدمة
  - الخسارة المالية، بما في ذلك المسؤولية التنظيمية والتعويضات والمسؤولية القانونية
  - فقدان السمعة، بما في ذلك نقص الخدمة ومعلومات الموظف أو العميل
  - فقدان الملكية الفكرية، بما في ذلك تصميم منتج جديد أو سر تجاري.
- يتم تحديد مستوى أثر الهجوم الناجح على المؤسسة من خلال قيمة الخسارة، مع العلم بأن القيمة قد لا تكون دائمًا قيمة نقدية.
- معرفة أن تهديدات الأمن السيبراني تختلف بمرور الوقت وأن مؤسسات الأمن السيبراني تقدم تحديثات منتظمة حول وضع التهديدات الحالي والمتغير.

(أ2) ثغرات النظام

تطبيق فهم ثغرات النظام التي تؤثر على المؤسسات في مجموعة من القطاعات والسيناريوهات المهنية.

- تتعرض مختلف أنواع أجهزة الكمبيوتر و/أو النظام لتهديدات مختلفة وبالتالي فهي تحتوي على ثغرات مختلفة. تتضمن الثغرات المحتملة ما يلي:
  - الشبكة، بما في ذلك منافذ جدار الحماية وأجهزة التخزين الخارجية
  - الثغرات التنظيمية، بما في ذلك أذونات الملفات أو الامتيازات وسياسة كلمة المرور
  - البرامج، بما في ذلك الواردة من مصدر غير موثوق به، والبرامج التي تم تنزيلها، والنسخ غير القانونية وإدخال لغة SQL وعمليات الاستغلال الفورية
  - نظام التشغيل، بما في ذلك الإصدارات غير المدعومة والتحديثات غير المثبتة
  - الأجهزة المحمولة التي تعتمد على الشركات المصنعة للمعدات الأصلية (OEMs) لتحديث برامج النظام

- الثغرات المادية، بما في ذلك سرقة المعدات، وأجهزة التخزين بنظام الناقل التسلسلي العالمي (USB) التي تحتوي على بيانات حساسة، وجمع كلمات المرور وغيرها من المعلومات من خلال أساليب devices with sensitive data, collection of passwords and other information by الهندسة الاجتماعية
- عملية كيفية استخدام الأشخاص للنظام، بما في ذلك التسريبات ومشاركة تفاصيل الأمان
- الآثار الأمنية للحوسبة السحابية وأجهزة إنترنت الأشياء (IoT).

- مكان العثور على مصادر حديثة للمعلومات حول ثغرات أمنية محددة في الأجهزة والبرامج المعروفة.
- **نو اقل الهجوم، بما في ذلك:** Wi-Fi، و®Bluetooth، **والاتصال بالإنترنت، والوصول إلى الشبكة الداخلية.**

(أ3) المسؤوليات القانونية

تطبيق فهم المسؤوليات القانونية للمؤسسات في مجموعة من السيناريوهات القطاعية والمهنية فيما يتعلق بالأمن السيبراني.

- التشريعات واللوائح الدولية والإقليمية لحماية البيانات.
- سياسة/قانون إساءة استخدام الكمبيوتر وتعديلاته، وتعريفاته للممارسات والتطبيقات غير القانونية.
- تشريعات الاتصالات، ومتطلبات السماح للشركات بمراقبة اتصالات الموظف واستخدام الإنترنت أثناء العمل.
- تشريعات سياسة الاحتيال - المتطلبات الخاصة بالتعامل مع الخدمات باستخدام الأساليب القائمة على تكنولوجيا المعلومات بهدف سرقة المعلومات لأغراض احتيالية
- اللوائح الدولية التي تتناول الصحة والسلامة في العمل وحقوق وواجبات أصحاب العمل والموظفين في العمل.

(أ4) تدابير الأمان المادي

تطبيق فهم تدابير الأمان المادي التي يمكن للمؤسسات تطبيقها في مجموعة من القطاعات والسيناريوهات المهنية.

- استخدام وفعالية تدابير الأمان المادي، بما في ذلك:
  - أقفال أمان الموقع، وإدخال البطاقات، والقياسات الحيوية، وكاميرات المراقبة (الدوائر التليفزيونية المغلقة (CCTV))، وموظفي الأمن، وأجهزة الإنذار، والكابلات المحمية والخزائن
  - تخزين البيانات وحماية البيانات وإجراءات النسخ الاحتياطي، بما في ذلك النسخ الاحتياطي الآلي المخطط له وتخزين البيانات داخل الموقع وخارجه والتخزين السحابي.

(أ5) تدابير أمان البرامج والأجهزة

تطبيق فهم تدابير الأمان التي يمكن للمؤسسات تطبيقها في مجموعة من القطاعات والسيناريوهات المهنية.

- استخدام وفعالية تدابير أمان البرامج والأجهزة، بما في ذلك:
  - برامج مكافحة الفيروسات وتقنيات الكشف، بما في ذلك توقيعات الفيروسات، وتقنيات الاستدلال المستخدمة لتحديد محتوى الملف المشبوه المحتمل، وتقنيات التعامل مع التهديدات المحددة
  - جدران حماية البرامج والأجهزة وتقنيات التصفية التي تستخدمها، بما في ذلك:
    - تصفية الحزم وفحصها
    - الوعي بطبقة التطبيقات
    - القواعد الواردة والصادرة
    - عنوان الشبكة

- مصادقة المستخدم
  - إجراءات تسجيل دخول المستخدم
  - كلمة المرور القوية
  - كلمة مرور نصية ورسومية
  - المصادقة البيومترية
  - التحقق بخطوتين
  - رموز الأمان، بما في ذلك المفاتيح المستندة إلى USB والمفاتيح الحقلية القريبة
  - المصادقة القائمة على المعرفة، بما في ذلك أزواج الأسئلة والأجوبة
  - مصادقة شبكة Kerberos لأنظمة التشغيل القائمة على نظام التشغيل Windows® ونظام التشغيل Linux®
  - المصادقة المستندة إلى الشهادة
- عناصر التحكم في الوصول وطرق تقييد وصول المستخدمين إلى الموارد، بما في ذلك التطبيقات والمجلدات والملفات والموارد المادية
- الحوسبة الموثوقة.

- الغرض من التشفير واستخداماته، بما في ذلك:
  - التخزين الآمن لكلمات المرور
  - إدارة الحقوق الرقمية (DRM)
  - تشفير الملفات والمجلدات والأقراص
  - تشفير الاتصالات
    - الأجهزة المدمجة، بما في ذلك الهواتف الذكية والأجهزة اللوحية
    - جهاز التوجيه البصلي (تور)
    - الشبكات الافتراضية الخاصة (VPN)
    - الشهادات الرقمية وسلطات شهادات الاعتماد
    - بروتوكول نقل النص التشعبي الآمن (HTTPS)
    - مفاتيح عامة/خاصة.
- الاحتياطات التي يمكن اتخاذها لحماية الشبكة المحلية اللاسلكية (WLAN) من الوصول غير المصرح به، بما في ذلك:
  - تصفية عنوان MAC وإخفاء معرف مجموعة الخدمة (SSID)
  - التشفير اللاسلكي - الخصوصية السلكية المكافئة (WEP) والوصول المحمي بتقنية Wi-Fi 2 (WPA2) والإعداد المحمي بتقنية Wi-Fi (WPS)، مما يخفف من الثغرات اللاسلكية المعروفة
  - النظر في مشكلات الأمان أثناء تصميم الشبكة والنظام لضمان دمج الأمان من مرحلة التطوير.

هدف التعلم (ب): استكشاف الآثار الأمنية للأنظمة المتصلة بالشبكة

(ب1) أنواع الشبكات

ميزات اختيار الشبكات لأغراض مختلفة وآثار ذلك المترتبة على الأفراد والمؤسسات.

- التطبيقات وميزات الشبكات:
  - شبكة المنطقة المحلية (LAN)، WLAN، الشبكة الواسعة (WAN)، شبكة منطقة التخزين (SAN)، شبكة المنطقة الشخصية (PAN)
  - الإنترانت، الإكسترانت، الإنترنت، السحابة
  - التكامل السلكي واللاسلكي.
- تطبيقات وميزات هياكل الشبكة:
  - الهياكل المادية، بما في ذلك الهيكل النجمي، والهيكل النجمي الموسع، والهيكل الهرمي، والشبكة اللاسلكية، والهياكل المخصصة (مزيج من الهياكل السلكية واللاسلكية لاستخدام جهازك الشخصي في العمل (BYOD))
  - الهياكل المنطقية، بما في ذلك معايير الإيثرنت للهياكل السلكية واللاسلكية (العائلة 802).

- تطبيقات وميزات بنية الشبكة:
  - نظير إلى نظير
  - العميل/الخادم
  - العميل منخفض الأداء (الحاسوب الرقيق).
- الاتجاهات الحديثة، بما في ذلك التطبيقات والميزات: المحاكاة الافتراضية، والحوسبة السحابية، ونظام BYOD، والشبكات المحددة بالبرمجيات (SDN)، والشبكات المحددة بالتخزين وإنترنت الأشياء.
- التحلي بالقدرة على تفسير وتعديل المخططات التخطيطية للشبكة باستخدام البرامج المناسبة.

(ب2) مكونات الشبكة

ميزات توصيل الأجهزة لتشكيل شبكة وآثار ذلك على الأفراد والمؤسسات.

- تطبيق وميزات مكونات الأجهزة، بما في ذلك:
  - أجهزة المستخدم النهائي، بما يشمل الأجهزة المحمولة
  - أجهزة الاتصال، بما في ذلك المحولات وأجهزة التوجيه ونقاط الوصول والأجهزة متعددة الوظائف ولوحات وصل USB وأجهزة المودم
  - وسائط الاتصال، بما في ذلك الكبل والنظام اللاسلكي (Wi-Fi و®Bluetooth والأشعة تحت الحمراء (IR))، والألياف الضوئية وشبكة Li-Fi.
- تطبيقات وميزات الوسائط الخارجية والتخزين، بما في ذلك محركات الأقراص المحمولة والوسائط الضوئية.
- تطبيقات وميزات مكونات البرامج، بما في ذلك:
  - أنظمة تشغيل الشبكة والأجهزة
  - أدوات مراقبة الشبكة وإدارتها واستكشاف الأخطاء وإصلاحها، بما في ذلك مراقبة الأداء وعارض الأحداث والسجلات وماسحات الثغرات الأمنية وأجهزة التقاط الحزم
  - تطبيقات الشبكة، بما في ذلك قواعد البيانات وإدارة المستندات وأدوات اكتشاف الشبكة.

(ب3) خدمات وموارد البنية التحتية للشبكات

تطبيق خدمات الشبكة وأثرها على المؤسسات.

- تطبيق ووظيفة:
  - بروتوكول التحكم في الإرسال /بروتوكول الإنترنت (TCP/IP)
  - المنافذ
  - الحزم
  - ترجمة عناوين الشبكة (NAT)، بما في ذلك بنية عناوين IPv4 وIPv6 وعناوين RFC 1918 الخاصة.
- تطبيق أنظمة تشغيل الشبكة، بما في ذلك النطاقات والنطاقات الفرعية.
- تطبيق أجهزة الشبكة لتكوين الشبكات، بما في ذلك تجزئة الشبكة.
- وظيفة وتطبيق خدمات البنية التحتية للشبكة، بما في ذلك:
  - نظام أسماء النطاقات (DNS)
  - خدمات الدليل (DS)، بما في ذلك الدليل النشط، والدليل المفتوح، OpenLDAP
  - خدمات المصادقة
  - بروتوكول التكوين الديناميكي للمضيف (DHCP)
  - التوجيه
  - خدمات الوصول عن بُعد.

- خدمات وموارد شبكة الوظائف والتطبيقات:
  - خدمات الملفات والطباعة
  - خدمات الويب والبريد والاتصالات.

هدف التعلم (ج): وضع خطة حماية الأمن السيبراني لمؤسسة محددة

(ج1) تقييم الثغرات في أنظمة الكمبيوتر

التعرف على كيفية تقييم الثغرات في نظام الحاسوب لدى المؤسسة في سيناريوهات مختلفة.

الفهم:

- أنواع واستخدامات الأدوات والأساليب المتبعة لتقييم الثغرات الأمنية في أنظمة الكمبيوتر، بما في ذلك ماسحات المنافذ، ومدقق التسجيل، وأجهزة فحص الثغرات الأمنية في مواقع الويب، وبرامج اكتشاف الثغرات الأمنية وإدارتها، وتقييم ثغرات المستخدم
- الغرض من إجراء مراجعة خارجية مستقلة لتصاميم النظام والشبكة قبل التنفيذ
- تطبيقات وميزات اختبار الاختراق للتهديدات الشائعة، تلك الموجودة في وثيقة "أكبر 10 تهديدات" الصادرة عن مشروع أمان تطبيقات الويب المفتوحة (OWASP).

(ج2) تقييم شدة المخاطر في كل تهديد

التعرف على كيفية تقييم شدة المخاطر لنظام الكمبيوتر لدى المؤسسة في سيناريوهات مختلفة.

- الخطر هو التهديد الذي قد يؤدي إلى حدوث شكل من أشكال الخسارة في وقت ما.
- شدة المخاطر = احتمال حدوث التهديد × مستوى/قيمة الأثر المتوقع للخسارة.
- تشمل تدابير شدة المخاطر ما يلي:
  - شدة المخاطر = منخفضة ومتوسطة ومرتفعة ومتطرفة
  - احتمال حدوث التهديد = غير محتمل (كل عام تقريبًا)، محتمل (تقريبًا كل أسبوع أو شهر) محتمل للغاية (مرة واحدة أو أكثر تقريبًا في اليوم)
  - مستوى التأثير/قيمة الخسارة = طفيفة ومتوسطة وكبيرة.
- التحلي بالقدرة على استخدام مصفوفة شدة المخاطر التالية:

احتمال حدوث التهديد	محتمل للغاية	متوسطة	مرتفعة	متطرفة
	محتمل	منخفضة	متوسطة	مرتفعة
	غير محتمل	منخفضة	منخفضة	متوسطة
		طفيفة	معتدلة	كبيرة
مستوى الأثر/قيمة الخسارة				

- نهج تقييم المخاطر:
  - يتم إجراء تقييمات المخاطر أثناء تصميم النظام (المراجعة) وعلى فترات منتظمة أثناء التشغيل (التدقيق) وبعد الاختراق الأمني، حيث أن التهديدات مستمرة ومتغيرة باستمرار
  - ستقوم طريقة تقييم المخاطر بما يلي:
    - تحديد التهديدات المحتملة وتقييم احتمالية حدوث تهديدات مختلفة
    - تقييم الثغرات الأمنية في نظام متصل بشبكة الكمبيوتر لتهديدات محددة
    - تقييم مستوى الأثر/قيمة الخسارة المحتملة
    - تحديد شدة المخاطر (المنخفضة والمتوسطة والمرتفعة والمتطرفة).

(ج3) خطة الأمن السيبراني للنظام

الغرض من خطة الأمن السيبراني وتطويرها لمؤسسة ما في سيناريوهات مختلفة.

- وضع خطة لنظام متصل بالشبكة، بما في ذلك:
- تدابير حماية الأمن السيبراني التي يتعين اتخاذها (الإجراءات) لأشد المخاطر (المتوسطة والمرتفعة والمتطرفة) التي تنطوي على أكبر مستوى أثر/قيمة خسارة والتي من المرجح أن تحدث، بما يشمل:
  - تدابير حماية الأجهزة، بما في ذلك جدران الحماية وأجهزة التوجيه ونقاط وصول لاسلكية
  - تدابير حماية البرامج، بما في ذلك مكافحة البرامج الضارة وجدار الحماية وفحص المنافذ، وحقوق الوصول وتوافر المعلومات
  - تدابير الحماية المادية، بما في ذلك الأقفال وكاميرات المراقبة وأجهزة الإنذار وتخزين البيانات والنسخ الاحتياطية
  - تدابير إدارة المخاطر البديلة، بما في ذلك نقل المخاطر إلى طرف خارجي (تكليف أحد مزودي الخدمة)، وتجنب المخاطر عن طريق إيقاف النشاط وقبول المخاطر
- تبرير حول كيفية قيام كل إجراء حماية مخطط له بحماية النظام من الهجوم
- نظرة عامة على أي قيود فنية ومالية
- نظرة عامة على المسؤوليات القانونية
- نظرة عامة على قابلية استخدام النظام، بما في ذلك درجة تأثير القيود الأمنية على كفاءة النظام من حيث سهولة إكمال المهام وتجربة المستخدم
- الخطوط العريضة لتحليل التكلفة والفائدة فيما يتعلق بتنفيذ تدابير الحماية
- خطة اختبار للتحقق من أن تدابير الحماية تعمل على النحو المنشود، بما في ذلك وصف الاختبار والنتيجة المتوقعة والإجراءات الإضافية المحتملة بعد الاختبار.

(ج4) السياسات الداخلية

فهم السياسات الداخلية التي تؤثر على المؤسسات المختلفة.

- الغرض من سياسات تكنولوجيا المعلومات العامة المتعلقة بالأمان ومحتواها وفعاليتها، بما في ذلك:
  - فهم متطلبات إعداد سياسة الأمن السيبراني باستخدام دورة "التخطيط-التنفيذ-التحقق-التصرف" المستمدة من جزء من المنظمة الدولية للتوحيد القياسي 27001:2013 (ISO)
  - سياسات المؤسسة وتطبيقها، بما في ذلك السياسات المتعلقة باستخدام الإنترنت والبريد الإلكتروني، وإجراءات الأمان وكلمة المرور، ومسؤوليات الموظفين، والتدريب على أمن تكنولوجيا المعلومات للموظفين
  - عمليات تدقيق الأمان وتطبيقها للتحقق من الامتثال للسياسات سياسة النسخ الاحتياطي - اختيار البيانات والأساليب (الكاملة والتدريجية)، والتكرار والتخزين
  - سياسة حماية البيانات - لضمان الامتثال التنظيمي للتشريعات ذات الصلة.

- الغرض من سياسة الاستجابة للحوادث ومضمونها والإجراءات المرتبطة بها:
  - تجميع فريق الاستجابة لحوادث أمن الكمبيوتر (CSIRT) والأدوار في الفريق، بما في ذلك قائد الفريق وقائد الحوادث والأعضاء المنتسبين
  - إجراءات الإبلاغ عن الحوادث، بما في ذلك ما يُشكل الحادث الأمني، وكيفية الإبلاغ عنه والجهة التي سيتم إبلاغها
  - التقييم الأولي للحادث، بما في ذلك تحديد ما إذا كان هذا حادثًا حقيقيًا، نوع الهجوم وشدته
  - إبلاغ الحادث إلى فريق الاستجابة لحوادث أمن الكمبيوتر والأفراد الآخرين ذوي الصلة
  - احتواء الضرر وتقليل المخاطر
  - حماية سلامة الأشخاص
  - حماية البيانات الحساسة والبيانات الأخرى، مع الحرص على حماية أكثرها قيمة أولاً
  - حماية الأجهزة والبرامج
  - تقليل التعطيل في موارد الحوسبة
  - تحديد نوع وشدة الاختراق، بما في ذلك طبيعة الهجوم والغرض منه وأصله والأنظمة والملفات التي تم اختراقها
  - حماية الأدلة وإنشاء نسخ احتياطية للأدلة واستعادة البيانات، بما في ذلك إزالة الأقراص الصلبة الأصلية وتخزينها
  - إخطار الوكالات الخارجية، إذا كان ذلك مناسبًا، ومناقشة الخيارات مع الممثلين القانونيين، والاتصال بالوكالات الخارجية مثل وكالات إنفاذ القانون والأمن الخارجي وخبراء الفيروسات
  - استعادة الأنظمة وتحديد النقطة الزمنية التي حدث فيها الاختراق واستعادة النسخ الاحتياطية قبل تلك النقطة الزمنية
  - تجميع وتنظيم وثائق الحادث، بما في ذلك الوثائق التي أنشأها فريق الاستجابة لحوادث أمن الكمبيوتر لتحديد تفاصيل الخرق والإجراءات المتخذة
  - معرفة أهمية الحفاظ على الوثائق التي قد تكون ضرورية لمقاضاة الجناة وترتيبها
  - مراجعة النتائج لتحديث السياسات وتحسين التدريب.
- الموضوعات التي يتم تناولها عادةً في خطة التعافي من الكوارث والغرض منها:
  - تحديد الأنظمة الحرجة وتعريفات هدف وقت الاسترداد (RTO) وهدف نقطة الاسترداد (RPO)
  - استراتيجيات الوقاية والاستجابة والتعافي للأنظمة الحرجة، بما في ذلك
    - الأشخاص المسؤولون
    - المرافق والمعدات المطلوبة
    - موقع وتنسيق النسخ الاحتياطي للبيانات
    - اتصال الشبكة وعرض النطاق الترددي
    - موردو المعدات والأشخاص
  - تعريف إجراءات الاسترداد لكل نظام حرج
  - هيكل خطة التعافي من الكوارث الذي يتبع ISO 27031/24762 أو المعادلات الدولية الأخرى ذات الصلة، بما في ذلك
    - مقدمة
    - الأدوار والمسؤوليات
    - إجراءات الاستجابة للحوادث
    - تفعيل خطة التعافي من الكوارث
    - الإجراءات التي يجب اتباعها.

(ج5) مزودو الخدمة الخارجية

فهم المشكلات المرتبطة بمزودي الخدمة الخارجيين.

- ستشمل اتفاقيات مزود الخدمة الخارجية (ESP) ما يلي:
  - السحابة
  - الأجهزة
  - البرامج.
- الآثار المترتبة على اتفاقيات مزودي الخدمة الخارجيين (ESP)، بما في ذلك:
  - الملكية القانونية والولاية القضائية، بما يشمل الموقع الجغرافي، وحركة البيانات عبر الحدود والإجراءات عند انتهاء الاتفاقية
  - الحماية الأمنية، بما في ذلك التزامات أمن البيانات والخصوصية والتشفير والمسؤولية عن انتهاكات البيانات والمسؤولية عن فقدان البيانات أو تلفها (سواءً العرضي أو المتعمد) وإجراءات التعافي من الكوارث
  - حل النزاعات، بما في ذلك المتطلبات القانونية، والمشكلات التي تواجهها البيانات والمعالجة الموجودة في ولايات قضائية متعددة.
- يتم تغطية العديد من هذه النقاط أو جميعها بقوانين حماية البيانات.

هدف التعلم (د): فحص إجراءات جمع الأدلة الجنائية بعد وقوع الحادث الأمني

(د1) جمع الأدلة الجنائية

فهم كيفية جمع الأدلة باستخدام أدوات الطب الشرعي المختلفة.

- جمع الأدلة الجنائية بعد وقوع حادث أمني والغرض منه.
- الإجراءات الجنائية المكتبية:
  - تلبية متطلبات الإجراءات الجنائية المكتبية، بما في ذلك
    - مصادرة الأجهزة
    - التقاط صورة للنظام
    - استخدام أداة التحليل الجنائي
    - مراجعة الملفات والإعدادات
    - مراجعة سجلات النظام
    - مراجعة نشاط المستخدم
    - تحليل البرامج الضارة والتنبيهات
  - تحديات الإجراءات الجنائية المباشرة
    - تغيير البيانات في الموقع
    - استعادة البيانات التالفة ومنع تلف البيانات
    - تسجيل البيانات في الذاكرة النشطة
    - فقدان الملفات المؤقتة.
- الإجراءات الجنائية للشبكة:
  - الاتفاق على منهجية اختبار الشبكة مع الإشراف الجنائي وسلطة التحقيق
  - مسح البنية التحتية المحلية
    - ضمان منح الإذن
    - التأكد من أن بروتوكول الاختبار لن يعطل أي نظام مباشر
    - أدوات التحليل السلبي والنشط
  - مراجعة وتحليل جدران الحماية وأجهزة البنية التحتية، بما في ذلك المحول أو جهاز التوجيه أو نقطة الوصول اللاسلكية أو سجلات العميل أو الخادم router, wireless access point, client or server logs
  - تحليل نشاط البرامج الضارة والتنبيهات.

(د2) التحليل الجنائي المنهجي لنظام مشبوه

فهم ميزات التقرير الجنائي للنظام في المؤسسات المختلفة.

- متطلبات الاحتفاظ بسجل دقيق يتم إجراؤه في ذلك الوقت، أو في أقرب وقت ممكن بعد وقوع الحادث.
- الاحتفاظ بلقطات من النظام.
- متطلبات تسجيل جميع النتائج والنظر في مدى موثوقية الأدلة.
- متطلبات تسجيل أي تعديلات يتم فرضها عن قصد أو عن غير قصد من قبل المحقق.
- متطلبات إنشاء دليل مرئي للنتائج.
- التأكد من أن الأدلة ذات صلة وليست إيجابية زائفة.
- تقييم النتائج لتحديد ما إذا كانت:
  - تقدم دليل على أي جريمة و/أو حادث
  - تظهر أن النظام قد تعرض للاختراق خارجيًا و/أو داخليًا
  - تدعم بقوة سببًا محتملاً واحدًا أكثر من الأسباب المحتملة الأخرى.
- تقديم توصيات لمنع تكرار الحوادث الأمنية في المستقبل، بما في ذلك التحسينات على:
  - محتوى وثائق الأمن السيبراني (السياسات و/أو الاتفاقيات)
  - الالتزام بوثائق الأمن السيبراني (السياسات و/أو الاتفاقيات)
  - تدابير الحماية الأمنية (المادية و/أو المتعلقة بالبرامج و/أو الأجهزة).

معايير التقييم

النجاح	التفوق	الامتياز
هدف التعلم (أ): فهم تهديدات الأمن السيبرانى وثغرات النظام وأساليب الحماية الأمنية		
A.P1 شرح تهديدات الأمن السيبراني المختلفة التي يمكن أن تؤثر على أنظمة تكنولوجيا المعلومات في المؤسسات. **A.P2** شرح ثغرات النظام التي يمكن أن تؤثر على أنظمة تكنولوجيا المعلومات في المؤسسات. **A.P3** شرح كيف يمكن للمؤسسات استخدام تدابير الأمان المادي والبرمجية والأجهزة لمواجهة التهديدات الأمنية.	**A.M1** تقييم الأثر الذي يمكن أن تحدثه تهديدات الأمن السيبراني على أنظمة تكنولوجيا المعلومات في المؤسسات مع مراعاة المتطلبات القانونية.	**AB.D1** تقييم فعالية التدابير المستخدمة لحماية المؤسسات من تهديدات الأمن السيبراني مع مراعاة المتطلبات القانونية.
هدف التعلم (ب): استكشاف الآثار الأمنية للأنظمة المتصلة بالشبكة		
B.P4 شرح كيف يمكن تأمين أنواع ومكونات الشبكات المختلفة. **B.P5** شرح كيفية تأثير الأمن السيبراني على البنية التحتية للشبكات ومواردها.	**B.M2** تحليل الآثار الأمنية لمختلف الأنظمة المتصلة بالشبكة.	
هدف التعلم (ج): تطوير خطة حماية الأمن السيبراني		
C.P6 إجراء تقييم للمخاطر لثغرات النظام. **C.P7** وضع خطة الأمن السيبراني لنظام تكنولوجيا المعلومات في المؤسسة.	**C.M3** تبرير اختيار التدابير الأمنية المستخدمة للدفاع عن أنظمة تكنولوجيا المعلومات الخاصة بالمؤسسة.	**CD.D2** تقييم خطة الأمن السيبراني، بما في ذلك أثرها على السياسات الداخلية ومزودي الخدمات الخارجية.
هدف التعلم (د): فحص إجراءات جمع الأدلة الجنائية بعد وقوع الحادث الأمني		
D.P8 شرح الإجراءات الجنائية لجمع الأدلة بعد وقوع حادث أمني.	**D.M4** تحليل كيفية تنفيذ الإجراءات الجنائية على نظام مشبوه.	

معلومات أساسية للواجبات

يجري تقييم هذه الوحدة باستخدام موجز الواجبات المحددة من قبل بيرسون. ويجب استخدام واجب محدد لتقييم المتعلمين.

المعلومات الإضافية الخاصة بالمعلمين والمقيّمين

الاحتياجات من الموارد

بالنسبة لهذه الوحدة، يجب أن يتمتع المتعلمون بإمكانية الوصول إلى أنظمة تكنولوجيا المعلومات الموجودة عادةً في المدارس والكليات والمكاتب مثل:

- أجهزة الكمبيوتر الشخصية
- تطبيقات الإنتاجية للمكاتب، على سبيل المثال معالجة النصوص وقواعد البيانات وجداول البيانات
- الاتصال بالشبكة
- الاتصال بالإنترنت

لا توجد موارد متخصصة إضافية مطلوبة لهذه الوحدة.

المعلومات الأساسية بشأن قرارات التقييم

سيُظهر المتعلمون عبر هذه الوحدة خصوصية الفكر والجمع المستقل والترتيب والحكم على الأدلة.

وسيتم إعطاء اسم المؤسسة وتفاصيلها للمتعلمين في الواجب المحدد.

أهداف التعلم (أ) و(ب)

بالنسبة لمعيار الامتياز، سيقوم المتعلمون بإعداد تقييم لفعالية التدابير المستخدمة لحماية المؤسسات من تهديدات الأمن السيبراني والآثار المترتبة عليها مع مراعاة المتطلبات القانونية. وسيطبق المتعلمون المعرفة والفهم للأمن السيبراني في سيناريوهات غير مألوفة من أجل تحديد المخاطر الشائعة وغير الشائعة، واستخدام مجموعة واسعة من تدابير الحماية الأمنية لتأمين نظام متصل بالشبكة موجود بشكلٍ شامل.

ومن المقرر أن تظهر الأدلة التواصل الكتابي/الشفوي عالي الجودة من خلال استخدام المفردات الفنية الدقيقة والسلسة، والتي تدعم الاستجابة جيدة التنظيم والمدروسة بما يربط سلاسل التفكير بوضوح.

بالنسبة لمعيار التفوق، سيقوم المتعلمون بتقييم الأثر الذي يمكن أن تحدثه تهديدات الأمن السيبراني على أنظمة تكنولوجيا المعلومات في المؤسسات، مع مراعاة المتطلبات القانونية.

وسيقدم المتعلمون تحليلاً منطقيًا ومفسرًا جيدًا استنادًا إلى الآثار الأمنية لمختلف الأنظمة المتصلة بالشبكة.

سيستكشف التحليل مدى التأثير الذي تحدثه الآثار المحددة على المؤسسة.

وسيكون التحليل متوازنًا ومدعومًا بأمثلة واضحة.

يجب أن تكون الأدلة دقيقة من الناحية الفنية وأن يتم إيصالها كتابيًا أو شفهيًا بجودة عالية.

ويمكن للمتعلمين تطبيق المعرفة والفهم للأمن السيبراني في سيناريوهات غير مألوفة من أجل تحديد المخاطر الشائعة وغير الشائعة، واستخدام مجموعة من تدابير الحماية الأمنية لتأمين نظام متصل بالشبكة موجود بشكلٍ شامل. ويمكنهم تقديم مبرر سليم لتصميمهم. ويمكن للمتعلمين تصميم اختبارات لمجموعة من إجراءات الأمان.

يمكن للمتعلمين تحليل بعض الأدلة الجنائية المعقدة المتعلقة بالحوادث الأمنية لإنتاج استنتاجات متماسكة ومقنعة، جنبًا إلى جنب مع الاحتمالات البديلة. ولديهم القدرة على تحديد مجموعة من الثغرات الأمنية في سيناريو معين وتقديم اقتراحات صحيحة وواقعية ومبررة بشكلٍ أساسي للتحسين.

وسيستخدم المتعلمون بشكلٍ أساسي المصطلحات الفنية المناسبة باستمرار لتوصيل أفكارهم.

بالنسبة لمعيار النجاح، سيقدم المتعلمون تفسيرات حول تهديدات الأمن السيبراني وثغرات النظام وكيفية مواجهتها.

كما سيقومون بشرح كيفية تأمين أنواع ومكونات الشبكات المختلفة، بالإضافة إلى كيفية تأثير الأمن السيبراني على البنية التحتية للشبكات ومواردها.

يجب على المتعلمين تطبيق معرفتهم وفهمهم للأمن السيبراني في سيناريوهات غير مألوفة من أجل تحديد المخاطر الشائعة واستخدام تدابير الحماية الأمنية المألوفة بغرض تحسين أمن النظام المتصل بالشبكة الحالي.

سيستخدم المتعلمون بعض المصطلحات الفنية المناسبة بغرض توصيل أفكارهم.

هدفا التعلم (ج) و(د)

بالنسبة لمعيار الامتياز، سيعتمد المتعلمون على معرفتهم لإنتاج تقييم لخطة الأمن السيبراني، بما في ذلك تأثيرها على السياسات الداخلية ومزودي الخدمات الخارجيين. سيقوم المتعلمون أيضًا بتقييم التأثير الذي يمكن أن تحدثه التحقيقات الجنائية على المؤسسة.

وسيستند التقييم إلى مراجعة متوازنة وواسعة النطاق للخطة الأمنية وتأثير خضوعها للتحقيق الجنائي في أنظمة تكنولوجيا المعلومات وفيما بينها.

وسيستخدم المتعلمون المصطلحات الفنية المناسبة باستمرار لتوصيل أفكارهم.

بالنسبة لمعيار التفوق، سيقدم المتعلمون تحليلاً واضحًا ودقيقًا ومتوازنًا لكيفية تنفيذ الإجراءات الجنائية على الأنظمة المشبوهة. ويجب عليهم النظر في جميع الإجراءات الجنائية في محتوى الوحدة كدليل يسترشدون به. ويجب على المتعلمين أيضًا تقديم مبررات واضحة للتدابير الأمنية المستخدمة للدفاع عن أنظمة تكنولوجيا المعلومات في مؤسسة معينة.

بالنسبة لمعيار النجاح، سيقوم المتعلمون بإجراء تقييم للمخاطر لثغرات النظام في مؤسسة معينة. وسيعملون على وضع خطة للأمن السيبراني لصالح مؤسسة معينة إضافة إلى استكشاف الإجراءات الجنائية لجمع الأدلة أثناء سير التحقيق الجنائي.

سيستكشف المتعلمون كيف يمكن استخدام الإجراءات الجنائية لجمع الأدلة بشأن نظام مشبوه.

ضوابط التقييم

الوقت: هذا الواجب له فترة زمنية موصى بها. وهذا على سبيل التوصية فقط ويمكن تعديله وفقًا لاحتياجات المتعلمين.

الإشراف: ينبغي أن تكون واثقًا من موثوقية عمل المتعلم. وهذا يعني هذا أنه قد يتوجب إخضاع المتعلمين للإشراف.

الموارد: يجب أن يتمكن جميع المتعلمين من الوصول إلى أنواع الموارد نفسها لإكمال الواجب.

البحث: ينبغي إعطاء المتعلمين الفرصة لإجراء البحوث خارج سياق التعلم إذا استدعى الواجب ذلك.

ارتباط هذه الوحدة بالوحدات الأخرى

- ترتبط هذه الوحدة بما يلي:
- الوحدة 1: نظم تكنولوجيا المعلومات - الإستراتيجية والإدارة والبنية الأساسية
- الوحدة 4: البرمجة
- الوحدة 9: إدارة مشاريع تكنولوجيا المعلومات

فرص تطوير مهارات العمل القابلة للنقل

عند إكمال هذه الوحدة، ستتاح للمتعلمين الفرصة لتطوير مهاراتهم ومعرفتهم في مجال تكنولوجيا المعلومات، بما في ذلك الأجهزة والبرامج والشبكات. وسيتمكن المتعلمون أيضًا من تعزيز قدرتهم على استخدام المنطق والاستدلال.